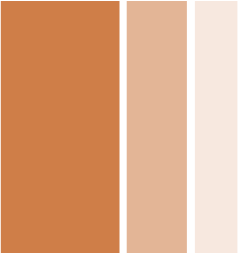


PROCESO DE AUDITORÍA INFORMÁTICA



U.D. AUDITORÍA INFORMÁTICA

SESION : 03

ING. CLAUDIA RUBIO JIMENEZ

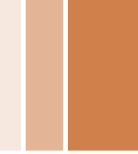


INSTITUTO DE
EDUCACIÓN SUPERIOR
TECNOLÓGICO PÚBLICO
"PAIJÁN"

NORMAS DE CONVIVENCIA

- ✓ Respetarse entre compañeros
- ✓ Trabajar con responsabilidad
- ✓ No está permitido jugar con los celulares, computadoras, escuchando música, viendo videos no relacionados a la sesión de aprendizaje.
- ✓ Está prohibido comer dentro y durante la sesión de clase.
- ✓ Ser puntuales en asistir a clases.
- ✓ Cuidar el monitor, CPU, teclado, mouse, cables de red, entre otros.





MÓDULO FORMATIVO:

Gestión de Plataformas y Servicios de TI

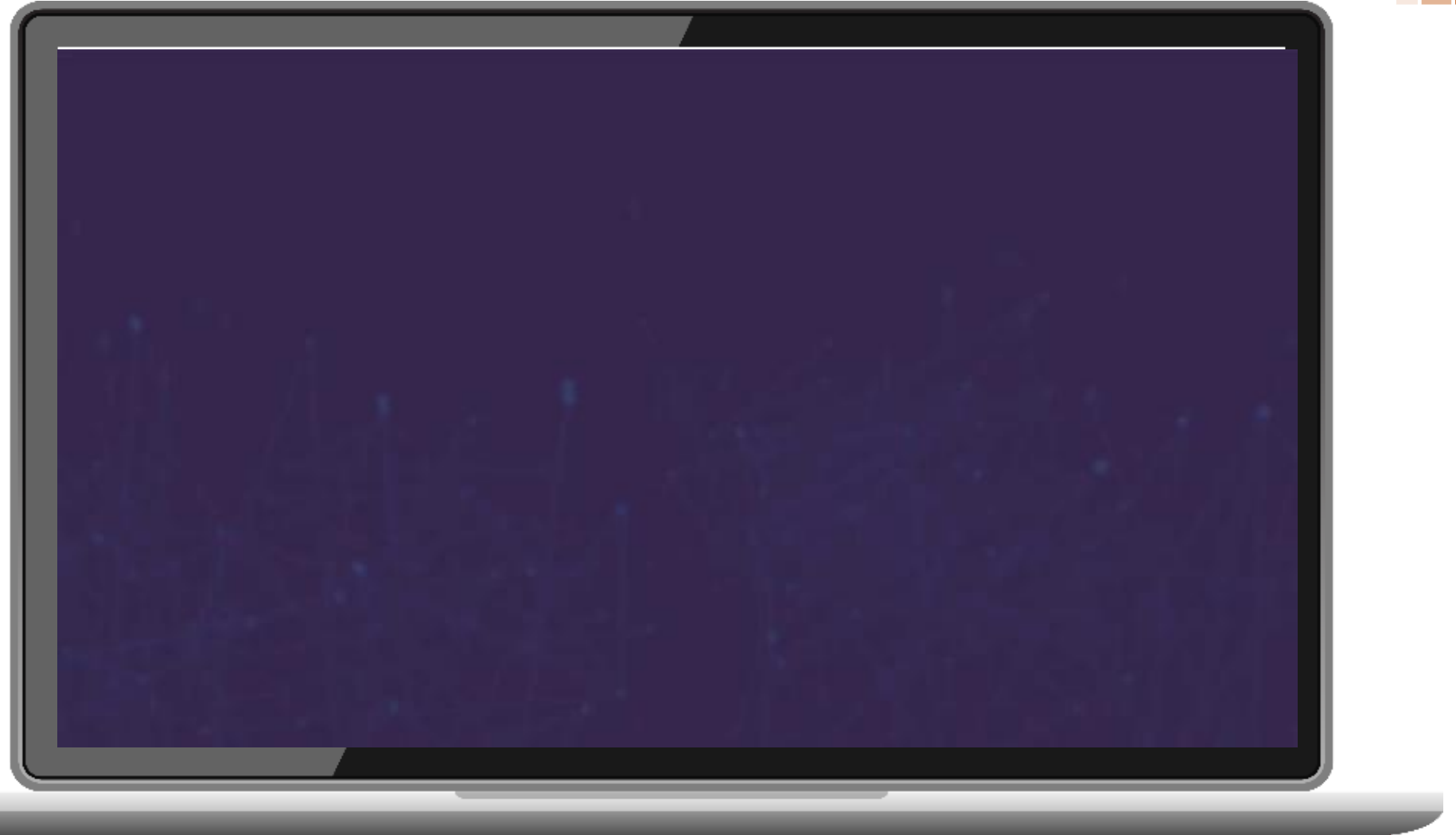
LOGRO DE LA SESIÓN:

Al finalizar la sesión, el estudiante diseña una estructura de proceso de Auditoria Informática para una Empresa ficticia.

**“Proceso de
Auditoría
Informática”**

Fuente: Youtube

[https://www.youtube.com/
watch?v=STxaAFyVM30&t=6
58s](https://www.youtube.com/watch?v=STxaAFyVM30&t=658s)



Las diez etapas del proceso de auditoría informática, en orden.

- | | |
|---|--|
| 1 Planificación
Definir el marco de trabajo de la auditoría | 6 Evidencias
Recolectar los datos que sustentan las conclusiones |
| 2 Alcance
Delimitar sistemas, procesos y áreas a revisar | 7 Análisis
Interpretar la evidencia frente a los criterios |
| 3 Objetivos
Establecer qué se busca lograr con la auditoría | 8 Hallazgos
Documentar las desviaciones detectadas |
| 4 Criterios
Fijar los estándares con los que se comparará | 9 Informes
Comunicar resultados y recomendaciones |
| 5 Procedimientos
Determinar las técnicas para recabar información | 10 Seguimiento
Verificar la implementación de las mejoras |

¿Qué es la auditoría informática?

Es el examen sistemático, objetivo e independiente de los sistemas de información, la infraestructura tecnológica y los controles de una organización, con el fin de evaluar su fiabilidad, seguridad y cumplimiento normativo.



Sistemática

Sigue un proceso ordenado y repetible, no acciones aisladas.



Objetiva

Se basa en evidencia verificable, sin sesgos ni intereses particulares.



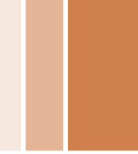
Independiente

El auditor no interviene en la operación de lo que evalúa.

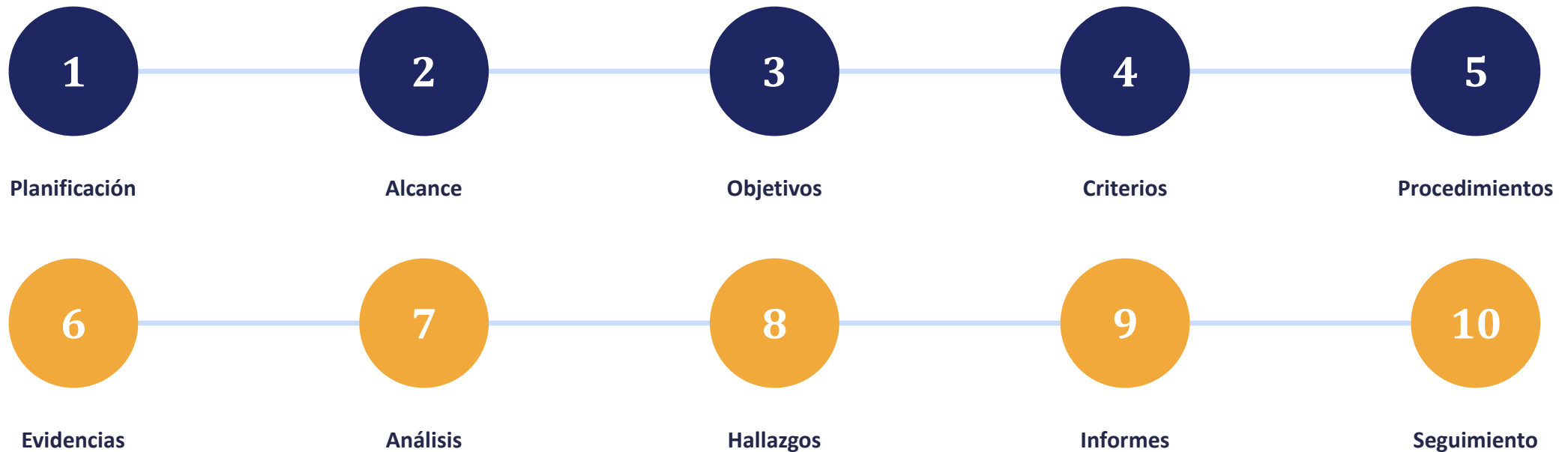
¿Por qué importa?

- Reduce riesgos tecnológicos y operativos
- Fortalece la seguridad de la información
- Verifica el cumplimiento normativo
- Mejora la toma de decisiones de TI

El proceso de auditoría: visión general



Diez etapas secuenciales que conducen de la planificación al seguimiento de resultados.

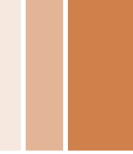


Etapa inicial en la que se define cómo se llevará a cabo la auditoría: qué se revisará, con qué recursos, en qué tiempos y bajo qué enfoque metodológico.

- 1 Conocer la organización y su entorno tecnológico
- 2 Identificar riesgos preliminares
- 3 Definir el equipo auditor y sus responsabilidades
- 4 Elaborar el cronograma y presupuesto de trabajo
- 5 Seleccionar el enfoque y las herramientas a usar

EL PLAN DE AUDITORÍA INCLUYE

- Alcance preliminar
- Objetivos generales
- Recursos y roles
- Cronograma
- Riesgos identificados



El alcance delimita las fronteras de la auditoría: qué sistemas, procesos, ubicaciones y periodos serán evaluados, y cuáles quedan explícitamente fuera.

1

Sistemas y aplicaciones

Qué plataformas, software o infraestructura se revisan.

2

Procesos de negocio

Qué flujos operativos apoyados en TI se incluyen.

3

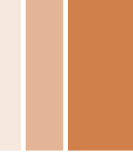
Periodo de tiempo

El rango temporal que cubren las pruebas y evidencias.

4

Ubicaciones físicas

Sedes, centros de datos o unidades de negocio incluidas.



Los objetivos precisan qué se pretende lograr con la auditoría: son la razón de ser de todo el ejercicio y guían la selección de criterios y procedimientos.

1

Seguridad

Evaluar la protección de datos, accesos y activos de información.

2

Cumplimiento

Verificar el apego a normas, leyes y políticas internas.

3

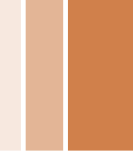
Eficiencia

Analizar el uso adecuado de los recursos tecnológicos.

4

Confiabilidad

Comprobar la integridad y exactitud de la información.



Los criterios son los estándares, normas o marcos de referencia contra los cuales se compara la situación real encontrada durante la auditoría.

1

COBIT

Marco de gobierno y gestión
de TI empresarial.

2

ISO/IEC 27001

Estándar de gestión de
seguridad de la información.

3

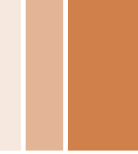
ITIL

Buenas prácticas para la
gestión de servicios de TI.

4

Políticas internas

Normativas propias definidas
por la organización.



Son las acciones concretas que el auditor ejecuta para obtener información y evidencia sobre el objeto auditado.

1

Entrevistas

Conversaciones con el personal responsable de los procesos.

2

Observación

Verificación directa de la ejecución de controles y tareas.

3

Revisión documental

Análisis de políticas, manuales, bitácoras y registros.

4

Pruebas técnicas

Comprobaciones sobre configuraciones, accesos y datos.

El auditor apoya sus procedimientos en herramientas que aumentan la cobertura y precisión de las pruebas.

1 Software CAAT (técnicas de auditoría asistidas por computador)

2 Escáneres de vulnerabilidades y análisis de configuración

3 Listas de verificación (checklists) basadas en el criterio elegido

4 Muestreo estadístico para seleccionar transacciones o registros

5 Cuestionarios de control interno

La evidencia es toda información que el auditor recopila para sustentar sus conclusiones. Debe ser suficiente, competente y relevante.

- 1 **Testimonial:** Declaraciones obtenidas en entrevistas
- 2 **Documental:** Políticas, contratos, bitácoras, reportes
- 3 **Física:** Inspección directa de equipos o instalaciones
- 4 **Analítica:** Resultado de cálculos, comparaciones y pruebas

CUALIDADES DE LA EVIDENCIA

Suficiente

Cantidad adecuada para respaldar la conclusión

Competente

Confiable y obtenida de fuente válida

Relevante

Vinculada directamente con el objetivo auditado

Consiste en interpretar la evidencia recolectada, comparándola contra los criterios definidos, para determinar si existen desviaciones y comprender su origen.

1

Organizar la evidencia recolectada

2

Comparar la situación real frente al criterio

3

Identificar brechas o desviaciones

4

Determinar posibles causas y efectos

Aquí suelen aplicarse técnicas de análisis de datos, indicadores de control y comparación de tendencias.

Un hallazgo documenta una desviación relevante detectada en el análisis. Su estructura estándar facilita la comprensión y la acción correctiva.



El informe comunica de forma clara y objetiva los resultados de la auditoría a la dirección y a las partes interesadas.

- | | |
|-------------------------------|---------------------------------|
| 1 Resumen ejecutivo | 5 Conclusiones generales |
| 2 Objetivos y alcance | 6 Recomendaciones |
| 3 Metodología aplicada | 7 Anexos y evidencia |
| 4 Hallazgos detectados | |

El lenguaje debe ser claro, objetivo y orientado a la toma de decisiones.

El seguimiento cierra el ciclo de auditoría: verifica que las recomendaciones se hayan implementado y que los riesgos hayan sido efectivamente mitigados.



Un hallazgo sin seguimiento es una oportunidad de mejora perdida.

Auditoría de accesos al sistema ERP de una empresa mediana.

Alcance	Módulo de gestión de usuarios y permisos del ERP
Objetivo	Verificar que los accesos respeten el principio de mínimo privilegio
Criterio	Política interna de control de accesos, alineada a ISO 27001
Evidencia	Listado de usuarios activos, matriz de permisos, bitácoras de acceso
Hallazgo	12 cuentas de exempleados seguían activas con permisos vigentes
Informe	Recomendación de depurar cuentas y automatizar la baja de accesos
Seguimiento	Verificación a 30 días: cuentas eliminadas y proceso automatizado

Errores comunes en la auditoría informática



Alcance mal definido

Genera revisiones incompletas o desviadas del objetivo real.



Criterios ambiguos

Sin un estándar claro, no hay forma objetiva de comparar.



Evidencia insuficiente

Debilita las conclusiones y expone al auditor a cuestionamientos.



Informes poco claros

Recomendaciones que la dirección no logra traducir en acción.



Falta de seguimiento

Los hallazgos se repiten en la siguiente auditoría.



Planificación deficiente

Provoca retrasos, sobrecostos y pérdida de foco.

Buenas prácticas a lo largo del proceso

- ✓ Documentar cada etapa con papeles de trabajo trazables
- ✓ Mantener comunicación constante con el auditado
- ✓ Basar cada hallazgo en evidencia suficiente y competente
- ✓ Priorizar hallazgos según su nivel de riesgo
- ✓ Redactar recomendaciones accionables, no solo señalar problemas
- ✓ Programar el seguimiento desde la planificación inicial

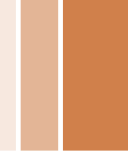
Resumen: el ciclo completo de la auditoría



De la planificación al seguimiento, cada etapa alimenta a la siguiente.



- ✓ Diseña el proceso de Auditoria Informática para una Empresa ficticia



... alguna pregunta?



REFERENCIA BIBLIOGRAFICA

- ✓ Piattini , M, Del Peso, E, & Del Peso, M. (2008). Auditoría de tecnologías y sistemas de información. RAMA. <https://www.alphaeditorialcloud.com/library/publication/auditoria-de-tecnologias-y-sistemas-de-informacion>



*Muchas
Gracias!*